

The AI Compliance Frontier: Balancing Innovation, Risk, and Data Protection

Serena Rocchio*
Politecnico di Torino

ABSTRACT

This report analyzes the ESCAPE seminar: “*The AI Compliance Frontier: Balancing Innovation, Risk, and Data Protection*” by Assistant Manager Paola Dabbicco and Consultant Valeria Polizzi from KPMG. The seminar was held on March 6, 2026.

The theme of the seminar is the regulation of Artificial Intelligence, with a particular focus on balancing technological innovation, risk management, and personal data protection.

1 INTRODUCTION

Artificial Intelligence (AI) is the ability of a machine to display human-like capabilities such as reasoning, learning, planning, and creativity. AI enables technical systems to perceive their environment, process what they perceive, solve problems, and act to achieve a specific goal. The computer receives data, already prepared or gathered through its own sensors such as a camera, processes it, and responds. AI systems are capable of adapting their behavior to a certain degree by analyzing the effects of previous actions and working autonomously.

Regulatory compliance is often underestimated in the technological world. Technologies must comply with rules and regulations. The risks of unregulated AI are: discrimination, incorrect automated decisions, data bias, privacy violations, economic and social impacts. In order to govern those complexities, the European Union (EU) has taken a proactive approach, setting strict standards through the General Data Protection Regulation (GDPR) and, more recently, the AI Act.

Given these premises, this paper aims to reflect on the position of the European Union to the regulation of AI.

2 SEMINAR OVERVIEW AND SUMMARY

2.1 EU AI Act

The AI Act is the European regulation on the use of Artificial Intelligence (AI). It is applicable to systems used in the EU that affect European citizens. It uses a risk-based approach. The goal of the AI Act is to ensure that AI systems are reliable, legal, ethical, and technically robust.

The AI Act came into force in August 2024 and is expected to be fully implemented, in the European Union, by August 2027. AI Act is applied in the European Union. Other countries are also developing similar regulations such as the USA, China, and Singapore. The global trend is the increasing regulation of AI.

2.2 Types Of Systems Regulated By AI Act

AI Act covers three different kinds of AI systems:

- **Machine Learning:** Systems that learn from data. If data are “poisoned” or biased, AI becomes “prejudiced” decision-maker.
- **Logic or Knowledge-Based Approaches:** Programs that operate strictly according to predefined rules, without context or judgment. They strictly follow an “If-Then” static decision, without human oversight.
- **Statistical Approach:** Algorithms calculating probabilities. If they are not transparent, we face “Black Box” outcomes that no one can explain.

2.2.1 Case Study: Amazon Recruiting Algorithm.

A case study of Machine Learning AI System is “The Amazon recruiting system” that was an AI trained on the CVs submitted over a 10-year period and mostly from men [3]. Consequently, the AI system learned how to penalize CVs containing the word ‘women’ or female names. In this case, the AI Act states that training data must be representative and free of bias to prevent systematic discrimination. Dabbicco claims that “This use case demonstrates that AI acts as a mirror. It does not fix any kind of human bias. A system that is trained on the past will always favor the status quo.”

2.2.2 Case Study: Dutch Childcare Benefits Scandal.

A case study of Logic or Knowledge-Based Approaches AI System is the “Dutch Childcare Benefits Scandal” [4]. The Dutch tax authorities introduced in 2013 an algorithmic system aiming to detect potentially fraudulent applications for child benefits. The system encoded non-Dutch citizenship as a higher risk factor received a higher risk score. For this reason, non-Dutch parents flagged by the system had their benefits suspended, were subjected to investigations, and benefit recovery policies. This led affected family to financial problems. This example shows how the system design strengthened existing institutional prejudices about the link between race, ethnicity and crime. The related article is Article 14 from the AI Act, which covered the human oversight. Dabbicco claims that “This case study demonstrates that humans must have the authority to ignore or reverse output coming from the AI system. Overseers must be trained to recognize any kind of limitation or failures of the AI system.”

2.2.3 Case Study: COMPAS Algorithm.

A case study of Statistical Approach AI System is the “COMPAS Algorithm” [12]. This algorithm was used by the US courts to predict recidivism. This system, by relying on data that reflected the existing social inequities, produced false positives for black defendants at twice the rate of white ones. This case study is related to Article 5 of AI Act, so the Prohibited AI Practices. Dabbicco claims that “This case demonstrates that an algorithm that is trained on a biased society will naturally replicate those biases. Every prediction should be subject to a human scrutiny and ethical auditing.”

* Author’s Contact Information: Serena Rocchio, Politecnico di Torino, Turin, Italy.

2.3 Actors Involved In The AI Act

Categories of regulated subjects:

- **Provider:** Entities that develop an AI System or have one developed with a view to placing it on the market or putting it into service under their own name or trademark.
- **Deployer:** The deployer could be any natural or legal person, public authority, agency or other body that is using the AI System for professional use.
- **Importer:** An importer is an EU-based legal entity or natural person that places on the EU market an AI System bearing the name or trademark of the Provider outside the EU.
- **Distributor:** A natural person or legal person in the supply chain, other than the provider and the importer, that makes an AI System available on the EU market.

2.4 Risk-Based Structure Of The AI Act

The EU AI Act takes a risk-based approach, layering obligations according to role and risk level of the AI product. The EU AI Act classifies AI systems into four risk categories (Fig.1):

- **Unacceptable Risk:** AI systems that pose a clear threat to people's safety, livelihoods and rights fall under this category. AI applications in this category are banned. This includes AI applications that manipulate human behavior, those that use real-time remote biometric identification (including facial recognition) in public spaces, and those used for social scoring.
- **High Risk:** This category includes a wide range of systems that could cause significant damage in the event of a malfunction: biometric identification and facial recognition systems, credit assessment and scoring systems, medical chatbots, autonomous driving systems.
- **Limited Risk:** AI systems in this category are subject to lighter transparency obligations. Developers and deployers must ensure that end-users are aware that they are interacting with AI. Examples include general-purpose chatbots or image processing software.
- **Minimal Risk:** This category includes systems with little or no impact on people's rights or safety, such as calculators, video games and spam filter. These systems are unregulated.

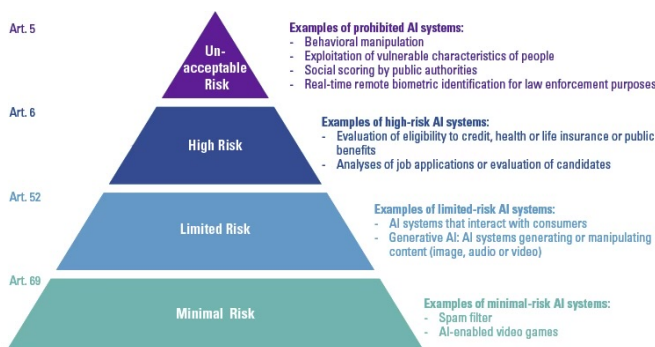


Figure 1: Risk-Based Structure Of The AI Act. (Source: [2])

2.4.1 High Risk System Requirements.

As highlighted by the law firm Wilson Sonsini [1], "The high-risk AI systems are subject to stringent requirements:

- Establish a risk management system, covering risk identification, testing, and the adoption of risk-mitigation measures.
- Apply data governance and management practices when training models.
- Draw up and update technical documentation and maintain automatic recording of events (logs).
- Provide instructions for use to the deployers who use the AI system.
- Ensure human oversight (e.g., including a "stop" button for human reviewers to interrupt the AI system).
- Achieve an appropriate level of accuracy, robustness, and cybersecurity of AI systems.
- Develop a post-market monitoring system to be able to detect any instances of malfunctioning.
- Undergo conformity assessment procedures before being released on the market.
- Register the AI system in a public database maintained by the EC.
- Notify EU regulators if the AI system poses risks to individuals' health and safety, or to fundamental rights, or in the event of a serious incident."

In the AI Act, Article 15 states that high-risk AI systems shall be resilient against attempts by unauthorised third parties to alter their use, outputs or performance by exploiting system vulnerabilities. The technical solutions aiming to ensure the cybersecurity of high-risk AI systems shall be appropriate to the relevant circumstances and the risks. The technical solutions to address AI specific vulnerabilities shall include, where appropriate, measures to prevent, detect, respond to, resolve and control for attacks trying to manipulate the training data set (data poisoning), or pre-trained components used in training (model poisoning), inputs designed to cause the AI model to make a mistake (adversarial examples or model evasion), confidentiality attacks or model flaws.

2.4.2 Example of High Risk System.

In many airports, facial recognition systems are now used at passport control to speed up identity checks. These systems compare a passenger's face with their passport data and flight information to confirm if passengers are allowed to pass. The disadvantage is that it involves biometric data and may generate some false positives and some false negatives. This makes them High Risk Systems.

To prevent bias and privacy violations, these tools must comply with the AI Act, ensuring that a human officer always monitors and verifies the machine's output.

2.5 GDPR

The General Data Protection Regulation (GDPR), defined by European Union (EU), regulates the rights of individuals over their personal data and standardizes privacy rules for organizations.

GDPR applies to any entity worldwide processing data of EU residents, demanding strict consent, security, and breach notification, with fines for non-compliance. The regulation was put into effect on May 25, 2018.

2.6 Common Elements Between AI Act And GDPR

The common elements between AI Act and GDPR are:

- Risk-based approach
- Impact assessment (DPIA for GDPR and FRIA for AI Act)
- Transparency
- Obligation to report incidents
- Demonstration of compliance
- Administrative sanctions
- Data security
- Human control
- Accountability.

2.7 Italian Approach To Regulation

In Italy, the Garante is the Data Protection Authority that is an independent administrative authority that protects fundamental rights related to the processing of personal data, ensuring compliance with the GDPR, AI Act and the Privacy Code. It monitors public and private entities, receives complaints and reports, and can block illicit treatment or sanction.

The most common violations that have been identified by the Garante are: lack of lawful basis, the insufficient transparency, inadequate protection for minors, discrimination and insufficient data anonymization.

2.7.1 Penalties Imposed By The Italian Garante.

A list of the administrative penalties imposed by Garante on companies includes a €20 million fine for Clearview AI [6], €2.6 million for Foodinho [5], and €15 million for OpenAI [7].

In January 2025, DeepSeek was banned by Garante [8]. This represented one of the first cases in which a data protection supervisory authority imposed a ban and blocked the operations of a company as large as DeepSeek.

2.7.2 Case Study: ChatGPT vs. Italian Garante.

In March 2023, OpenAI experienced a security incident involving a bug in an open-source library, which resulted in a data breach affecting 1.2% of ChatGPT Plus subscribers. This vulnerability caused exposed sensitive personal data, including users' conversations and the last four digits of credit cards to unauthorized users. [10]

This event prompted the Italian Data Protection Authority to issue a temporary limitation on the processing of Italian users' data, making Italy the first Western Nation to take such a restrictive measure against a major Generative AI provider. Beyond the immediate technical failure, the Garante utilized the breach as a legal basis to investigate broader systemic non-compliance with the General Data Protection Regulation (GDPR).

The investigation revealed several critical violations:

- **Absence of Age Verification:** A failure to prevent minors under 13 from accessing unsuitable content.

- **Lack of Legal Basis:** Insufficient justification for the massive collection and processing of personal data for algorithmic training.
- **Information Transparency:** Inadequate disclosure regarding how user data was being utilized.
- **Data Accuracy:** The tendency of the model to produce incorrect information about individuals, violating the GDPR principle of accuracy.

Although OpenAI complied by implementing global privacy updates and age-gating mechanisms, the case remains a landmark in tech regulation. It demonstrated that even global tech leaders are subject to the enforcement powers of National Supervisory Authorities, facing not only administrative fine (up to €20 million or 4% of global annual turnover) but also significant reputational risks.

2.8 KPMG Trusted AI Framework

KPMG has developed a framework for responsible AI. The principle pillars are:

- Human-centric
- Fairness
- Reliability
- Security
- Transparency
- Explainability
- Privacy and sustainability.

3 PERSONAL CONSIDERATIONS

The following paragraphs outline my personal considerations on Artificial Intelligence and its regulation.

3.1 The Illusion of Neutrality: AI Is Not Neutral

The case studies of Amazon and the Dutch scandal highlight a critical point: AI is not a neutral tool; it is a mirror of the data it consumes.

As pointed out by Keeru Chekuri (2025), AI is not neutral [9]:

"AI appears neutral because it is built on mathematics and data. Equations feel universal, and data looks like facts. But equations only work on the data we give them, and data is never raw, it is collected, labeled, and interpreted by people with specific worldview. The math itself is neutral it just finds patterns. But if the data is tilted, the results will be tilted too. The neutrality of AI is not a technical property but an epistemic and political one. With AI, neutrality becomes a question of inheritance (what biases it inherits from human systems), evolution (whether it develops beyond human categories) and control (who sets its objectives and boundaries)."

Acknowledging that data consists of more than mere row, but rather titled information, highlights how AI is prone to amplifying biases. Since these systems are built on human data, the risk is institutionalize and accelerate existing inequities.

3.2 Supervision By Humans Is Necessary

The seminar effectively demonstrated that human supervision is necessary; however, for this to be effective, it is essential that the operator receive adequate training beforehand. As Qiang [11] claims, an effective oversight depends on a specific set of cognitive and operational competencies:

"The Act mandates that high-risk AI systems must be designed and developed in such a way with appropriate human-machine interface tools, that they can be effectively overseen by natural persons. [...] It delineates particular instances wherein individuals tasked with human oversight responsibilities must be empowered to adequately discharge their duties. These instances encompass grasping the capabilities and constraints of the AI system, scrutinizing its functioning for aberrations or malfunctions, recognizing the presence of automation bias, accurately interpreting the system's outcomes, exercising judgment regarding the utilization or superseding of said outcomes, and intervening in the system's operations as deemed necessary. The requirement for human-machine interface tools and effective human oversight constitutes a legal duty of care imposed on AI system providers. The requirement can be seen as a standard of care expected from reasonable AI system providers. Failure to meet this standard could lead to negligence claims."

As the passage illustrates, the individual in charge of supervision must be able to: understand the capabilities and constraints of the AI system, scrutinizing malfunctions, recognizing bias, interpreting the system's outcomes, exercising judgment regarding outcomes, and intervening in the system's operations. Qiang underscores that any failure in human intervention could ground a claim for negligence. Ultimately, this framework repositions the human operator as the primary locus of responsibility.

3.3 The AI Act is Competitive In The Global Landscape

Despite the EU AI Act aims to protect fundamental rights, there is an ongoing debate about whether such a rigorous framework might slow down European organization compared to their American or Chinese competitors.

As pointed out by Susanna Villani, EU Law Researcher, AI Act can converge the global market towards standards based on the European Union value paradigm [13]:

"The European Union has repeatedly stated that it aspires to become a reference for the development and diffusion of AI according to an ethical and anthropocentric approach. [...] It should be noted, however, that the AI Act is not intended to affect the territory of the Union alone but also to strengthen its role as a global digital player. This is highlighted by the fact that, like other instruments adopted in the digital field (among all the GDPR), the rules established in the act in question have extraterritorial effect. In fact, [...] both deployers and AI system providers established in

third States will have to comply with the standards set out therein in order to sell their products and services on the European market. What is relevant overall for the operationalisation of the Regulation is not necessarily the geolocation of the entity that developed the IA system, but rather the spatial perimeter (i.e. the market) affected by the import and use of said systems, and the impact on natural or legal persons located in the Union. Well, the AI Act appears to have been conceived as a tool aimed, among other things, at linking the goal of promoting the development and deployment of reliable AI systems in the internal market with the Union's ambition to shape AI regulation globally, projecting its values and principles beyond its own borders. This holistic view of supranational action was duly recalled by the Commission in the report accompanying the proposal for a regulation, according to which «only common action at Union level can protect the digital sovereignty of the Union and exploit the Union's regulatory instruments and powers to shape rules and norms of global scope». In other words, the AI Act is not only a unilateral instrument of affirmation of the Union's technological sovereignty in the sphere of the internal market, but also a potential lockpick to facilitate (if not force) the convergence of third parties towards standards based on the Union's value paradigm in the broader global market."

Villani's analysis highlights two fundamental dynamics that redefine the role of the European Union in the global digital race.

First, it underlines the European's clear ambition to export its ethical values and regulatory standards beyond its geographical borders. This mechanism effectively turns European law into a global template for trustworthy AI.

Second, this convergence suggests that compliance should not be seen as a "barrier," but as a strategic advantage. The European framework is capable of attracting a growing base of users who prioritize data safety and fundamental rights over unregulated speed.

Just as the GDPR became the global gold standard for privacy, the AI Act positions European firms at the forefront of a market where trust is the most valuable currency.

4 CONCLUSION

The global AI landscape is under rapid transformation. Although AI is expected to bring many benefits to the European society, it also creates new threats that need to be properly addressed. In this context, the AI Act is of particular relevance, becoming a crucial element to ensure that AI systems deployed in high-risk scenarios are safe to use and respect fundamental rights of European citizens.

Regulatory compliance should not be interpreted as an obstacle to innovation, but rather as an essential requirement for its legitimacy. Risks such as the ineffectiveness of automated decisions and the social impact of unregulated models require robust institutional intervention. Through regulatory instruments such as the GDPR

and the AI Act, the European Union stands as a global leader in creating a secure, transparent digital ecosystem that respects human dignity.

REFERENCES

- [1] EU Artificial Intelligence Act. 2024. The eu artificial intelligence act. *European Union* (2024).
- [2] Stephan Idema Daniela Gonzalez. 2024. Understanding intersection between EU's AI Act and privacy compliance. (2024). <https://www.compact.nl/articles/understanding-intersection-between-eus-ai-act-and-privacy-compliance/>
- [3] Jeffrey Dastin. 2018. Amazon scraps secret AI recruiting tool that showed bias against women. (2018). <https://www.reuters.com/article/world/insight-amazon-scraps-secret-ai-recruiting-tool-that-showed-bias-against-women-idUSKCN1MK0AG/>
- [4] EU Law Enforcement. 2021. The Dutch benefits scandal. (2021). <https://eulawenforcement.com/?p=7941/>
- [5] Italian Data Protection Authority. 2021. Rider: Privacy Guarantor, no to discrimination based on algorithms. (2021). <https://www.garanteprivacy.it/home/docweb/-/docweb-display/docweb/9677377>
- [6] Italian Data Protection Authority. 2022. Facial recognition: the Italian Data Protection Authority fines Clearview €20 million. (2022). <https://www.garanteprivacy.it/home/docweb/-/docweb-display/docweb/9751323>
- [7] Italian Data Protection Authority. 2024. ChatGPT, the Italian Data Protection Authority closes its investigation. OpenAI will have to conduct a six-month information campaign and pay a €15 million fine. (2024). <https://www.garanteprivacy.it/home/docweb/-/docweb-display/docweb/10085432>
- [8] Italian Data Protection Authority. 2025. The Privacy Guarantor blocks DeepSeek. (2025). <https://www.garanteprivacy.it/home/docweb/-/docweb-display/docweb/10097450>
- [9] Chekuri Keeru. 2025. The myth of Neutral AI. Beneath the layers of complexity. *Medium* (2025).
- [10] The Hacker News. 2023. OpenAI reveals Redis bug behind ChatGPT user data exposure incident. (2023). <https://thehackernews.com/2023/03/openai-reveals-redis-bug-behind-chatgpt.html>
- [11] REN Qiang and DU Jing. 2024. Harmonizing innovation and regulation: The EU Artificial Intelligence Act in the international trade context. *Computer Law & Security Review* 54 (2024), 106028.
- [12] Michelle Anna Vaccaro. 2019. Algorithms in human decision-making: A case study with the COMPAS risk assessment software. (2019).
- [13] Susanna Villani et al. 2025. La via europea dell'IA nello scenario internazionale. In *The European Union on the international stage: challenges and transformations at the internal and external level*. Editoriale Scientifica, 297–330.